

HOT TOPICS · SUPPLIER AND DATA RISK

Know who holds your data.

A certificate authority left customer records, including some passports and driving licences, reachable from the internet for more than a year. A blockchain analytics firm found every user's credentials exposed. A practical playbook for the suppliers who hold what you cannot afford to lose.

INSIDE

Contents

A practical guide to the suppliers who verify identity or hold your most sensitive data: how to map them, what to demand of them, and what to do when one tells you it has been breached.

Foreword 03

Introduction 04

01 Map who holds what 06

02 Demand better 10

03 When they call 15

Questions and checklist 20

Sources 23

FOREWORD

The companies that check who you are can lose the proof.

In late October 2026 DigiCert, one of the best known names in website security, disclosed that a network migration in February 2025 had left an internal archive of customer records reachable from the internet. Most records held business contact details, but a small minority held passports, driving licences or utility bills that customers had uploaded to prove who they were.[1] The data was read in mid 2026 and the access was confirmed in October.[1,2]

In the same fortnight Chainalysis, whose tools many compliance teams use to screen crypto transactions, said an intrusion had exposed names, usernames, password hashes and live tokens for all its users. It took its main services offline while it rebuilt access.[3]

Neither firm's core service appears to have been subverted. But both cases make the same point: the suppliers you trust to verify identity, or to hold your credentials, are themselves a place your data can leak from. Most organisations cannot say which suppliers hold copies of their staff's passports, or which hold tokens that act on their behalf. This playbook helps you find out, fix the contracts and be ready for the call.



The Transputec team
Transputec

INTRODUCTION

Three habits make a supplier breach survivable.

You cannot stop a supplier making a mistake. You can decide what they hold, what they must tell you, and how fast you can respond.

Know who holds what

Keep one list of suppliers that hold identity documents, credentials, tokens or bulk personal data, with an owner for each.

Give them less, and bind them

Send only what is needed, have it deleted when done, and put notification, security and exit terms in writing.

Be ready for the call

Have a tested plan to rotate credentials, assess the risk and decide on reporting within 72 hours.

Every copy of a passport you hand a supplier is a copy you cannot recall.

A password can be changed in minutes. A passport scan, once leaked, stays leaked. That should change what you send, and what you let suppliers keep.

01

PART 01

Map who holds what.

Before you can demand anything, you need to know which suppliers hold your most sensitive data.

01 What happened at DigiCert and Chainalysis

02 Finding the suppliers that matter

03 Sorting them by what they hold

WHAT HAPPENED

Two breaches, one lesson

> **Suppliers in security and compliance are rarely questioned as hard as they should be.**

DigiCert's incident report is unusually candid. A migration moved an internal business system out from behind a VPN. It was treated as infrastructure work rather than a security change, so nobody reviewed what became reachable. A self-registration feature without multi-factor authentication was exposed, and a permissions gap let those accounts read archived records.[1]

Unknown accounts were spotted in June 2026 and treated as a sign-up problem. Only in October did DigiCert establish that records had been read between 27 June and 2 July. It says no certificates were affected, and it is still working out which individuals' documents were involved.[1,2]

Chainalysis's case moved faster but grew in the telling. Its first notice on 30 October described non-sensitive identity data. By 4 November it said all users' password hashes and live tokens had been exposed, and customers had to allowlist IP addresses, reset passwords and rotate API keys before services returned.[3]

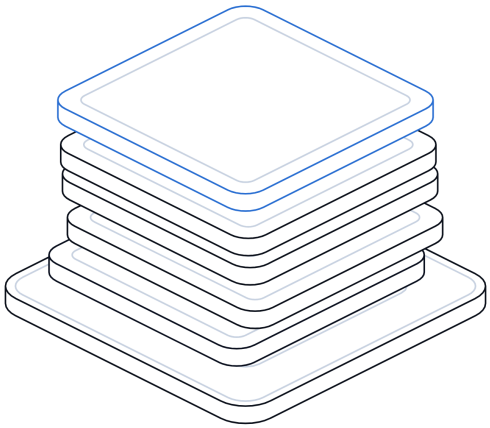
The two firms hold different things for different reasons. One keeps evidence of identity to validate customers. The other holds credentials that let customers use its platform. Both were trusted precisely because their job is security and compliance.

That trust is the problem. Suppliers in these categories are rarely questioned as hard as a new payroll or CRM provider, yet what they hold is often more dangerous to lose. Documents that prove identity can be reused for fraud for years, and tokens can act as you.

So start with a map. You do not need a perfect inventory of every supplier. You need to know, by the end of this month, which ones hold identity documents, credentials or bulk personal data, and who in your organisation owns each relationship.

FINDING THEM

Where sensitive data leaves your hands



01 **Identity checks**

Certificate authorities, right-to-work and background checkers, KYC platforms, ID verification in onboarding apps.

02 **Credentials and tokens**

SaaS tools, integrations and connected apps that store passwords, API keys or OAuth tokens for your users.

03 **Bulk records**

Payroll, pensions, HR, benefits, CRM and outsourced service desks holding staff or customer data.

04 **Privileged access**

Managed service providers and support firms with admin access, and the tools they use to reach you.

SORT THEM

Tier suppliers by what they hold

Spend your effort where a leak would hurt most. Review tier 1 first.

TIER	WHAT THEY HOLD	WHY IT MATTERS	MINIMUM YOU EXPECT
1. Identity	Passports, licences, proof of address, right-to-work evidence.	Cannot be changed after a leak; usable for fraud.	Deletion after checks, short retention, ID-specific breach terms.
1. Keys	Passwords, API keys, OAuth and session tokens.	Can act as you inside other systems.	MFA, IP allowlisting, rapid rotation on notice.
2. Bulk data	Staff or customer records at scale.	Large notification burden and regulatory exposure.	Article 28 contract, audit rights, tested exit.
2. Admin access	Privileged routes into your systems.	A breach there is a breach here.	Named accounts, logging, least privilege.
3. Low risk	Business contact details only.	Phishing risk, little else.	Standard terms and annual check.

02

PART 02

Demand better.

Send less, keep it for less time, and put the rest in a contract you can enforce.

01 Contract terms that matter

02 Assurance worth asking for

03 Minimisation, migration and exit

CONTRACT TERMS

Six clauses to check in every tier 1 contract

UK GDPR Article 28 sets the minimum for processors.[4] These go further where it counts.

01 Breach notice in hours, not "without undue delay"

The law requires a processor to tell you without undue delay; you have 72 hours to report.[5] Ask for 24 hours, with named contacts.

02 What they will tell you

Data types, people affected, time window, cause, and updates as scope changes.

03 Retention and deletion

Identity documents deleted once checks are complete, with written confirmation.

04 Sub-processors

A current list, notice of changes and the same terms passed down.

05 Security change control

Network and platform migrations reviewed as security changes, with re-checked monitoring.

06 Audit and exit

Rights to evidence and audit, plus return or deletion of all data at the end.

ASSURANCE

What each badge does, and does not, tell you

Certificates are a starting point. Ask what is in scope and how recent it is.

EVIDENCE	WHAT IT SHOWS	WHAT TO ASK
ISO/IEC 27001	A managed information security system, independently certified.	Is the service you use in scope? When does the certificate expire?
Cyber Essentials Plus	Basic technical controls, independently tested.	Does it cover the systems holding your data, not just the office?
SOC 2 Type II	Controls tested over a period by an auditor.	Read the exceptions section and the bridge letter.
Penetration test	Point-in-time testing of a system.	Date, scope and whether findings were fixed.
Your own questions	How they handle your data specifically.	Retention, deletion, migration review, breach history.

MINIMISATION

Five rules for sending less

UK GDPR expects you to keep personal data no longer than needed.[6] Apply the same test to what suppliers keep for you.

01 **Verify, then delete**

Ask for confirmation of a check, not a stored copy of the document.

02 **Send the least that works**

A redacted document or a reference number often does the job.

03 **Set a clock on every copy**

Agree a retention period for each data type, and check it is applied.

04 **Scope every token**

Grant integrations the narrowest permissions and shortest lifetimes they will accept.

05 **Clean up at exit**

Ending a contract is not the end of the data. Get deletion in writing.

Migration



When suppliers move, risk moves with them

DigiCert's exposure began with a network migration nobody reviewed as a security change. Ask how your suppliers handle theirs.

WHAT TO ASK

How are network and platform changes reviewed for security? Who signs them off?

WHAT GOOD LOOKS LIKE

An asset inventory updated with every change, and monitoring re-checked after it.

WATCH FOR

Internal tools moved to the cloud, sign-up features left switched on, archives no one uses.

YOUR SIDE

Ask to be told about major migrations of systems holding your tier 1 data.



OWNER

Supplier owner, with IT security

Bring this to the monthly review, with a date for each action.

03

PART 03

When they call.

A supplier tells you it has been breached. What to do in the first day, the first week and after.

01 The first 72 hours

02 Three scenarios

03 Your week, month and quarter plan

THE FIRST 72 HOURS

From the supplier's call to a decision

Your 72-hour reporting clock may start when you become aware of a breach of your data.[5]

Log and assign

Record the time you were told, name an incident lead and open a single channel with the supplier.

Establish what they held

Use your supplier map: which data types, which people, which credentials.

Cut and rotate

Reset passwords, rotate API keys and revoke tokens. Add IP allowlisting if offered.

Assess and decide

Judge risk to people and decide, with your DPO or adviser, whether to report to the ICO and tell individuals.

Track the scope

Expect the picture to change. Diarise follow-ups and revisit decisions with each update.

> **First statements often understate scope. Plan for the second and third update, not just the first.**

THREE SCENARIOS

What a supplier breach looks like in practice

HR AND SECURITY

Your ID checker leaks passports

THE TRIGGER

A verification supplier says some uploaded ID documents were exposed.

TELL PEOPLE

Warn affected staff about identity fraud and phishing; offer practical support.

DO FIRST

Ask exactly whose documents were held, and for what period.

FIX FOR NEXT TIME

Contract for deletion after checks, and stop sending full scans.

IT

A SaaS tool's tokens are exposed

THE TRIGGER

A platform says users' password hashes and live tokens were exposed.

CHECK

Logs for unusual use of the integration during the exposure window.

DO FIRST

Rotate keys, revoke tokens and reset passwords, including anywhere reused.

FIX FOR NEXT TIME

Shorter token lifetimes, IP allowlisting and SSO with MFA.

FINANCE AND HR

Your payroll provider is breached

THE TRIGGER

A processor reports theft of staff records held for you.

TELL PEOPLE

Clear, early message to staff with what to watch for.

DO FIRST

Confirm data types and numbers; start your 72-hour assessment.

FIX FOR NEXT TIME

Test the exit plan and check sub-processors.

PRIORITISE

Where to start

Plot suppliers by how sensitive the data is and how much you know about their controls.

↑ DATA SENSITIVITY

INVESTIGATE NOW

Sensitive, little known

Tier 1 suppliers with no recent evidence. Ask questions this month.

KEEP WATCH

Sensitive, well known

Good evidence on file. Review yearly and after any incident.

QUICK CHECK

Less sensitive, little known

Confirm basics and retention. Do not over-invest.

STANDARD TERMS

Less sensitive, well known

Normal contract terms and annual refresh.

WHAT YOU KNOW ABOUT THEM →

YOUR PLAN

This week, this month, this quarter

A realistic plan for most UK organisations. Owners are suggestions.

WHEN	DO THIS	OWNER
This week	Check whether DigiCert or Chainalysis hold your data; if so, rotate credentials and brief staff.	IT security lead
This week	Name a single owner for supplier data risk and set up a breach contact list.	COO or DPO
This month	Build the tier 1 supplier map: identity, keys, bulk data, admin access.	DPO with procurement
This month	Ask tier 1 suppliers the retention, migration and notification questions in this playbook.	Supplier owners
This quarter	Update contracts at renewal; rehearse a supplier breach as a tabletop exercise.	Legal and IT
This quarter	Delete or recall identity documents suppliers no longer need.	DPO

QUESTIONS

Questions for your board and your suppliers

Ask for evidence, not reassurance.

FOR THE BOARD

- ? Which suppliers hold copies of our people's identity documents, and why?
- ? Could we rotate every credential a supplier holds within 24 hours?
- ? Who decides whether a supplier's breach is reportable to the ICO?

FOR TIER 1 SUPPLIERS

- ? How long do you keep our identity documents, and can you prove deletion?
- ? How do you review network and platform migrations for security?
- ? How quickly will you tell us of a breach, and what will you tell us?

CHECKLIST

Do you know who holds your data?

Tick what is in place today. Anything left blank is your next step.

- [ ] **A tier 1 supplier map exists**
  Identity, keys, bulk data and admin access, with owners.

- [ ] **Identity documents are deleted after checks**
  Confirmed in contract and in writing.

- [ ] **Breach notice terms are in hours**
  With named contacts on both sides.

- [ ] **Supplier credentials can be rotated in a day**
  A runbook exists and has been tested.

- [ ] **MFA and allowlisting on supplier accounts**
  On every account you hold with tier 1 suppliers.

- [ ] **Migration and change questions asked**
  Answers on file for each tier 1 supplier.

- [ ] **A supplier breach exercise has been run**
  In the last 12 months.

GLOSSARY

Words worth knowing

Controller

Under UK GDPR, the organisation that decides why and how personal data is used.

Processor

An organisation that handles personal data on a controller's behalf, under contract.

Article 28 contract

The written terms UK GDPR requires between a controller and a processor.

Certificate authority

A trusted organisation that issues digital certificates after checking who is asking.

API key

A secret that lets one system use another's services. Treat it like a password.

Live token

A credential that keeps a session or integration logged in, often bypassing MFA.

IP allowlisting

Only accepting connections from approved network addresses.

Data minimisation

Collecting and keeping only the personal data you actually need.

Sub-processor

A supplier your supplier uses to handle your data.

Tabletop exercise

A structured walk-through of an incident to test plans and roles.

SOURCES

Sources and notes

Sources were accessed in November 2026. Where reports differ, we say so in the text. Early reporting on live incidents can change.

01 DigiCert, Unauthorized access to business system, incident report, Mozilla Bugzilla 2084460, Oct to Nov 2026, https://bugzilla.mozilla.org/show_bug.cgi?id=2084460

02 The Register, DigiCert admits 16-month security lapse exposed customer information, 6 Nov 2026, https://www.theregister.com/security/2026/11/06/digicert-admits-16-month-security-lapse-exposed-customer-information/5308097

03 Chainalysis, Security incident (updates 30 Oct to 7 Nov 2026), https://www.chainalysis.com/blog/security-incident-october-30/

04 legislation.gov.uk, UK GDPR Article 28: processor, https://www.legislation.gov.uk/eur/2016/679/article/28

05 legislation.gov.uk, UK GDPR Article 33: notification of a personal data breach, https://www.legislation.gov.uk/eur/2016/679/article/33

06 legislation.gov.uk, UK GDPR Article 5: principles, including storage limitation, https://www.legislation.gov.uk/eur/2016/679/article/5

TRANSPUTEC

Want to know who holds your data?

Transputec helps UK organisations map the suppliers that hold their sensitive data, tighten contracts and access, and respond fast when a supplier reports a breach.

Book a supplier risk review

transputec.com

READ THE COMPANION REPORT

Companion report: Trust, exposed

